XAuth: Efficient Privacy-Preserving Cross-Domain Authentication

Jing Chen, Zeyi Zhan, Kun He, Ruiying Du, Donghui Wang, and Fei Liu

Abstract—It is well known that each Public Key Infrastructure (PKI) system forms a closed security domain and only recognizes certificates in its own domain (such as medical systems, financial systems, and 5G networks). When users need to access services in other domains, their identities often cannot be recognized or PKI systems require extremely complex operations to authenticate the users' identities. This is the cross-domain authentication problem. The distributed consensus feature of blockchain provides a technical approach to solve this problem. However, there are some unresolved problems in existing blockchain-based schemes. On one hand, due to the low throughput of blockchain systems, the response speed may be insufferable when the number of cross-domain authentication requirements becomes enormous. On the other hand, these schemes insufficiently consider the privacy risk in the cross-domain scenario. In this article, we propose an efficient privacy-preserving cross-domain authentication scheme called XAuth that is integrated naturally with the existing PKI and Certificate Transparency (CT) systems. Specifically, we design a lightweight correctness verification protocol based on Multiple Merkle Hash Tree for rapid response. To protect users' privacy, we present an anonymous authentication protocol for cross-domain authentication. The security analysis and experimental results demonstrate that XAuth is secure and efficient.

Index Terms—Cross-domain authentication, public key infrastructure, blockchain, privacy-preserving

1 Introduction

Public Key Infrastructure (PKI) is a universal deployment in cyberspace, used to determine the uniqueness, authenticity, and legitimacy of entities by maintaining digital certificates. Generally, each PKI system (including the tree-like PKI system) forms a closed security domain, and only accepts the certificates issued by its own Certificate Authorities (CAs) [1]. Unfortunately, those closed domains lead to the cross-domain authentication problem in practice [2], [3].

For example, when users access the Internet, they usually need to rely on communication equipments from different suppliers (e.g., 5G base stations produced by Nokia and Ericsson). In reality, these communication equipments usually provide services for different carriers (such as AT&T and Verizon). However, due to business interest, different carriers have their own closed security domains and their certificates cannot be mutually recognized. To implement secure communications between those closed domains, the underlying communication equipments have to conduct some cross-domain authentication operations, such as switching CA certificates, installing different certificate systems on all equipments, or relying on some trusted third parties. These operations make certificate management dramatically complicated on the supplier side (e.g., Nokia) and become increasingly time-consuming as the number of cross-domain requests grows [4]. Such issue is even exaggerated in the emerging 5G networks which aim at lowering latency. Therefore, designing an efficient cross-domain authentication has become urgent in the current PKI construction.

Note that in cross-domain authentication, it is inappropriate to establish a centralized trusted third party or let one of CAs take the lead due to some obvious issues, such as a single point of failure and unfairness [5], [6]. The distributed consensus feature of blockchain inspires researchers to use it for designing mutual supervision authentication systems between different domains. Through establishing alliances, these schemes solve the problem of cross-domain authentication under the PKI system, such as CertCoin [7], Certchain [8], CertLedger [9], and BCTRT [10]. Nevertheless, due to negligence in design, most of them are not compatible with the Certificate Transparency (CT) system, which has been supported by mainstream CA institutions, browsers, and most Hypertext Transfer Protocol Secure (HTTPS) communications [11], [12], [13], [14]. Moreover, they have two other challenges as follows.

1) *Rapid response*. In the cross-domain authentication process, especially in 5G networks, users' demand for rapid response to identity verification is intense. On the other hand, the amount of identities that needs to be authenticated is enormous. For example, a security domain composed of Google already contains 870 million certificates, and the number of certificates is growing by 5 million every day [15]. However, the existing blockchain-based identity management schemes can only add 604,800 to 864,000 new identities data per day (because the processing speeds of Bitcoin and Ethereum are only about 7 and 10 transactions per second, respectively). When these new users need to conduct cross-domain access, the response speed of the existing solutions is unsatisfactory.

- *Jing Chen, Zeyi Zhan, Kun He, and Ruiying Du are with the School of Cyber Science and Engineering, Wuhan University, Wuhan 430072, China. E-mail: {chenjing, zhanzeyi, hekun, duraying}@whu.edu.cn.*
- *Donghui Wang and Fei Liu are with the Huawei, Shenzhen, Guangdong 518129, China. E-mail: {wangdonghui124, liufei19}@huawei.com.*

Manuscript received 24 Jan. 2021; revised 7 June 2021; accepted 9 June 2021. Date of publication 25 June 2021; date of current version 2 Sept. 2022. (Corresponding author: Kun He.)
Digital Object Identifier no. 10.1109/TDSC.2021.3092375

1545-5971 © 2021 IEEE. Personal use is permitted, but republication/redistribution requires IEEE permission.
See https://www.ieee.org/publications/rights/index.html for more information.
Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

Therefore, confronting massive identity data, how to improve the response speed of blockchain-based identity management schemes is a major challenge.

2) *Privacy protection*. Note that the existing privacy protection of blockchain aims to protect the privacy of identity data in the same domain scenario, not in the cross-domain scenario. Specifically, in the existing schemes, most of the cross-domain data is publicly visible. Some schemes even record identity operations to assure transparency and public audit. However, this behavior seriously threatens users' privacy. For instance, user identity data recorded by blockchain in systems (such as Certchain, CertLedger, and Certcoin) are at risk of leakage, and malicious entities can also analyze the access behaviors of any user through the public information of blockchain. Thus, designing a privacy protection scheme for cross-domain users is also an important challenge.

To solve the challenges discussed above, we propose an efficient privacy-preserving scheme for cross-domain authentication, called *XAuth*. XAuth is developed based on a three-layer architecture which includes storage layer, control layer, and application layer. Specifically, we adopt InterPlanetary File System (IPFS) [16] and blockchain technology to decouple storage and control layers. In summary, we make the following contributions:

1) To solve the cross-domain authentication problem in the PKI system, we propose a cross-domain authentication solution that decouples storage and control layers. In particular, our solution is compatible with both existing PKI and CT systems.
2) Aiming at the rapid response of XAuth, we design an efficient cross-domain data management mechanism. Specifically, we adopt a *Multiple Merkle Hash Tree (MMHT)* structure for processing large amounts of identity data. More importantly, we design a lightweight correctness validation protocol to improve the response speed of XAuth.
3) Towards users' privacy leakage, we propose a cross-domain anonymous authentication protocol. Through utilizing zero-knowledge proof algorithm and restricting the data types in the distributed ledger, XAuth can protect users' privacy in cross-domain authentication.
4) We conduct a security analysis of XAuth and implement a proof-of-concept prototype. Compared with existing schemes, XAuth is secure and efficient.

This paper is organized as follows. In Section 2, we give a description of the system model, threat model, design goals, and preliminaries. Next, we describe the architecture of XAuth in Section 3. In Sections 4 and 5, we introduce the efficient cross-domain data management mechanism and the privacy-preserving cross-domain authentication method, respectively. Then, we analyze its security properties in Section 6. In Section 7, we evaluate the performance of XAuth. Finally, we review the literature on existing cross-domain authentication schemes in Section 8 and conclude in Section 9.

2 Problem Statement

2.1 System Model

In our system, each security domain consists of four kinds of entities: *user*, *CA*, *IPFS node*, and *blockchain node*, as shown in Fig. 1. A security domain may be a private network, a departmental or corporate Intranet, or an independent business network. CA is the core of the system. In addition to issuing and revoking certificates, it needs to submit and review certificate operations as in Certificate Transparency (CT) [17]. In the CT system, all certificates are submitted to multiple public servers called log servers for public auditing and inquiring. Therefore, once a fraudulent certificate is publicly issued, it can be discovered by interested entities (domain owners or other CAs). This is essential for distributed cross-domain authentication. In XAuth, CA also needs to provide the service of anonymous authentication for users with cross-domain requirements.

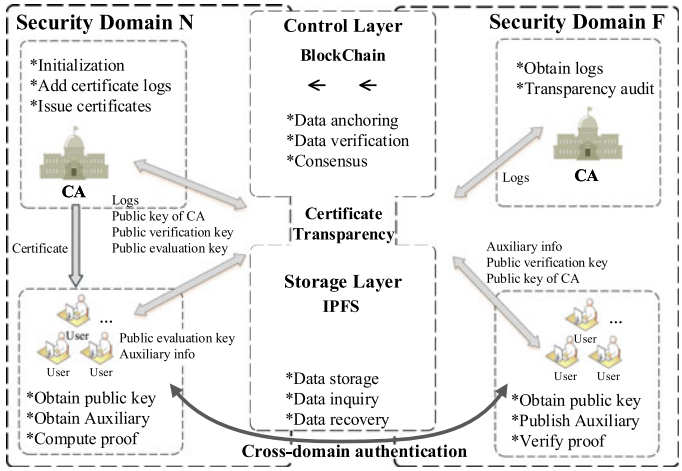


Fig. 1. Framework of XAuth.

The user can be a terminal device (e.g., a computer and a mobile phone) that intends to establish secure connections with another user in another security domain. When cross-domain access is required, the user verifies the certificate and generates anonymous proofs via XAuth, which utilizes blockchain and IPFS.

In detail, blockchain is adopted as a control layer to guarantee the consensus among different security domains and the integrity and consistency of cross-domain data. IPFS is utilized as a storage layer to share and transmit the original data for cross-domain authentication.

To facilitate distinction, the security domain in which users initiate the cross-domain request is called *native domain*. Relative to native domain, other security domains are called *foreign domains*.

2.2 Threat Model

From a practical perspective, we assume that an adversary has the following capabilities:

- The adversary cannot forge the users' identities without private key but can impersonate a legitimate user by using a similar identity.
- The adversary can attack the nodes in IPFS or blockchain, but cannot control more than 51 percent nodes in the entire network.
- The adversary can monitor, tamper, and forge the data flow of the victim.

2.3 Design Goals

Our primary objective is to achieve an efficient and privacy-preserving cross-domain authentication architecture with

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

decoupling storage and control layers. The architecture should own the following properties:

- *Cross-domain authentication*. Without extra certificates from other CAs, each security domain can establish and maintain trustworthy electronic relationships with other security domains.
- *Privacy protection*. The system needs to prevent leakage of users' identity data and behavioral privacy.
- *High throughput*. In consideration of massive certificates and operations from different security domains, XAuth should meet the high concurrency requirements to ensure the rapid response of the system.
- *Intrusion tolerance*. In case a fraudulent certificate similar to the identity of a legitimate user is issued, XAuth can effectively detect this misbehavior and take measures to prevent the situation from deteriorating.

2.4 Zero-Knowledge Proof (ZKP) Algorithm

To protect the privacy of users in cross-domain authentication, XAuth needs to adopt a ZKP algorithm in the anonymous authentication protocol. Particularly, the ZKP algorithm can convince the verifier that a certain assertion is correct without providing any useful information to the verifier. Concretely, the algorithm produces a proof π that is based on $F(u, w)$, where F is a predefined function with specific logical functions, u is a common reference input supplied by verifier, and w is a private input provided by the prover. Verifier can verify the correctness of π without exposing w. More detailed, the ZKP algorithm is defined as follows.

1) $(EK_F, VK_F) \leftarrow \mathbf{KeyGen}(F, 1^\lambda)$. This algorithm generates ZK keys according to the predefined function F and the security parameter λ. The keys contain a public evaluation key EK_F and a public verification key VK_F.
2) $(y, \pi_y) \leftarrow \mathbf{Compute}(EK_F, u, w)$. The prover computes the proof with the public evaluation key EK_F, the common reference input u supplied by the verifier, and a private input w. The output are $y \leftarrow F(u, w)$ and a proof π_y of y's correctness.
3) $\{0, 1\} \leftarrow \mathbf{Verify}(VK_F, u, y, \pi_y)$. The verifier checks the result y and its proof π_y by taking the public verification key VK_F and the common reference input u. The verification algorithm outputs 1 only when $F(u, w) = y$, and 0 otherwise.

3 XAuth Framework

3.1 Overview

XAuth is a three-layer architecture that adopts both blockchain and IPFS, as exhibited in Fig. 2. Unfortunately, in terms of storage efficiency and response speed, simply using the blockchain to store and query massive amounts of data for cross-domain authentication is inefficient. On the other hand, the IPFS technique can solve the efficiency problem, but it degrades the system security. To balance efficiency and security, we combine the characteristics of the two techniques by decoupling the storage and control layers. Specifically, we introduce IPFS as the storage layer to store and share the cross-domain data and utilize blockchain as the control layer to ensure the consistency and integrity of the data in the storage layer. The application layer is utilized to provide cross-domain anonymous authentication services. Overall, we implement the rapid response in the storage layer and control layer. At the application layer, we solve the problem of user privacy leakage in the cross-domain authentication process.

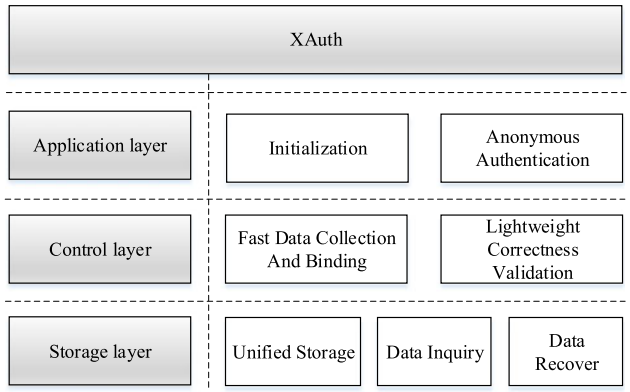


Fig. 2. Architecture of XAuth.

3.2 Storage Layer

The storage layer is composed of IPFS, which is used to reduce the I/O of blockchain and improve the response rate. The main functions of the storage layer including *storage*, *inquiry*, and *recovery* of cross-domain data. Data storage is adopted to store and synchronize the cross-domain data in different security domains. Data inquiry is applied to acquire the cross-domain data and check its integrity. Data recovery is utilized to recover the tampered or missing data from other nodes in the IPFS network, which is triggered when the integrity check fails. The details of these functions are introduced in Section 4.1.

Storage Format. In the storage layer, we not only store the original data, such as certificate operations, but also need to store the corresponding address returned by the blockchain for integrity check. To this end, we define a uniform storage format as follows. The format is implemented in JSON(JavaScript Object Notation) and stored in the storage layer as a file.

- `Data`: any data that needs to be stored. Its size is unlimited.
- `Data type`: the types of `Data` include CA public keys, Signed Certificate Timestamp (SCT), ZK keys, and certificate operations. Specifically, in XAuth, the CA public key and SCT are consistent with the existing PKI system and CT policy. ZK keys contain multiple generators [18], which are used to generate and verify zero-knowledge proofs. As for certificate operations, we adopt the pre-certificate defined in RFC 6962 [17] for the audit of certificate transparency.
- `Timestamp`: the time that `Data` is stored.
- `Address`: the address information of `Data` in blockchain.
- `Check time`: the latest time of integrity check for `Data`.
- `Extension`: An extension for storing other special types of data, such as Merkle hash tree.

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

3.3 Control Layer

Blockchain is served as the control layer, which contains two functions: *fast data collection and binding* and *lightweight correctness validation*. The first function is adopted to accommodate more certificate operations in transactions of the same size, and this function is executed before data storage. The second function occurs before anchoring data to the control layer. Anchoring data means storing the hash of data in the control layer. If the data and its hash value are inconsistent, our system should launch an alert. Thus, it is necessary to design a lightweight correctness validation function to quickly verify the consistency of the data. The processes of these functions are expanded in Section 4.2.

Multiple Merkle Hash Tree (MMHT). We do not store a single certificate operation directly in a transaction of the control layer. More specially, we design a structure named MMHT, which consists of two layers of Merkle Hash Tree (MHT). The leaf nodes of the lower layer MHT are the certificate operations, and the lower layer MHT is maintained by the IPFS nodes. The upper layer MHT is the same as in the original blockchain, and its leaf node is the root of the lower layer MHT. In brief, we store the root of the lower MHT composed of certificate operations in the transaction.

3.4 Application Layer

In application layer, we perform *system initialization* and *anonymous authentication*. System initialization contains two steps: 1) CAs in various domains establish system infrastructure including forming IPFS and blockchain networks. 2) Initialize zero-knowledge proofs and make trusted setup, which contains defining certificate verification as function F, setting security parameters, and generating public keys. The definition of function F determines whether ZKP can effectively prove the identity of the user. Therefore, we introduce the definition of function in detail in Section 5.2. Anonymous authentication based on ZKP algorithm is designed to protect user privacy during the cross-domain authentication, which includes anonymous proof generation and verification. The detailed description is given in Section 5.1.

The necessity of compatibility with CT. In blockchain, there are cases where some nodes behave maliciously after being attacked by adversaries. The incentive mechanism of blockchain effectively solves this problem by rewarding honest nodes with currency to verify the correctness of blocks and transactions. However, in blockchain-based identity management systems, the nodes are held by different CAs. The core goal of these CAs is to store certificates in blockchain and achieve cross-domain authentication. The malicious behavior of the node is more likely to store fraudulent certificates to impersonate legitimate users instead of maliciously mining blocks. Obviously, the incentive mechanism is no longer applicable. The CT system is designed to monitor CAs in nearly real-time and identify CAs that are maliciously issuing certificates. Under this system, CAs store certificate operations in public log servers and provide public auditing and monitoring services for stakeholders (domain name owners, client users, and other CAs). Through auditing and monitoring, illegal certificates will not be issued SCT, nor will they pass certificate verification. Therefore, it is critically necessary to be compatible with the CT system in cross-domain authentication.

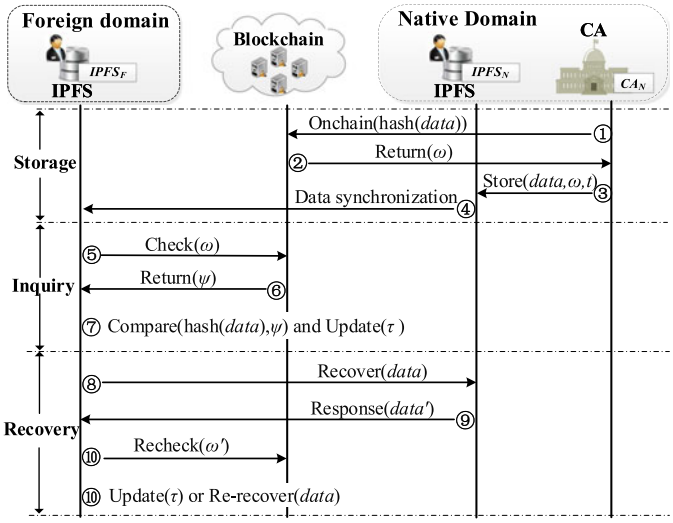


Fig. 3. Cross-domain data storage protocol.

4 Efficient Cross-domain Data Management

To achieve efficient cross-domain data management between different security domains, we design the cross-domain data storage protocol for the storage layer (Section 4.1) and the cross-domain data control protocol for the control layer (Section 4.2).

4.1 Cross-domain Data Storage Protocol

The cross-domain data storage protocol is mainly used for storage, inquiry, and recovery of data in the storage layer.

Details of the protocol are shown in Fig. 3. Four entities are included in this protocol: blockchain, the IPFS node $IPFS_F$ in the foreign domain, the IPFS node $IPFS_N$ and CA_N in the native domain. The protocol can be divided into three phases:

4.1.1 Data storage

CA_N first saves the hash of *data* in a blockchain transaction (Step 1). After the transaction is confirmed, CA_N receives the transaction address w from the blockchain (Step 2). Then CA_N stores *data*, address w, and the current time t in $IPFS_N$ using the uniform storage format defined previously. The *check time* in the format is initialized to the current time (Step 3). At last, $IPFS_N$ broadcasts and synchronizes the data across the entire network (Step 4).

4.1.2 Data inquiry

IPFS nodes need to check the integrity of cross-domain data periodically or according to user requirements to ensure data security and availability. To this end, $IPFS_F$ uses address w to query blockchain for the hash value ψ (Step 5-6). Then, $IPFS_F$ hashes *data* and compares the hash result with ψ. If it is consistent, the latest check time τ will be updated (Step 7); Otherwise $IPFS_F$ executes the data recovery of the protocol.

4.1.3 Data recovery

$IPFS_F$ initiates a data recovery request to the random node such as $IPFS_N$ for the missing data (Step 8). Then $IPFS_N$ resynchronizes data according to the request (Step 9). After

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

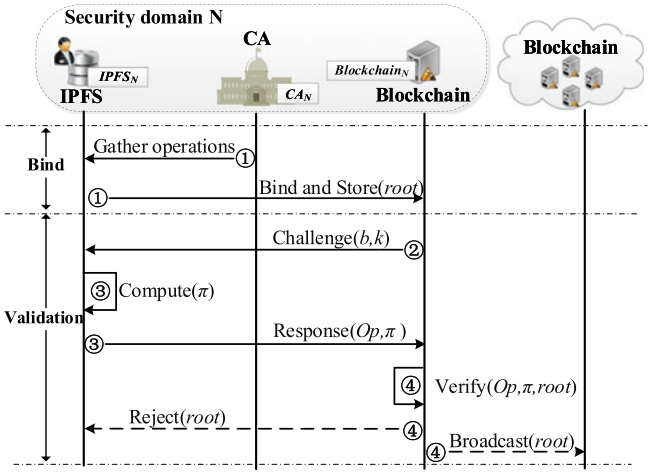


Fig. 4. Cross-domain data control protocol.

Step 1:		
1	$CA_N \rightarrow IPFS_N$:	Storage request for certificate operations
2	$IPFS_N$:	Construct an MHT from n operations
3	$IPFS_N \rightarrow Blockchain_N$:	Send the root $root$ of the MHT

Fig. 5. Fast data collection and binding.

receiving the new data $data'$, $IPFS_F$ performs data inquiry again (Step 10). If the result is still inconsistent, $IPFS_F$ continue to request data recovery from other nodes. To prevent endless requests, we set a threshold for requests. When the number of requests exceeds this threshold, the data will be discarded.

One may concern the impact of regular data inquiry on performance. Although this mechanism will bring frequent calculations and additional communication overhead, this overhead is relatively affordable for security improvements.

4.2 Cross-domain Data Control Protocol

The cross-domain data control protocol is used to bind data to the control layer and check its consistency before actual storage. This protocol is a key step for XAuth to ensure the credibility of cross-domain data. Three entities are included in this protocol: the IPFS node $IPFS_N$, CA_N, and the blockchain node $Blockchain_N$ in the native domain. The detail is shown in Fig. 4, which includes two phases:

4.2.1 Fast data collection and binding (see Fig. 5)

$IPFS_N$ collects n certificate operations requested for storage by CA_N. Then it sends the root of MHT formed by certificate operations to the blockchain node for binding (Step 1).

4.2.2 Lightweight correctness validation (see Fig. 6)

When $Blockchain_N$ receives $root$ to be stored, it needs to validate the correctness between the root and the certificate operation. First, $Blockchain_N$ randomly selects b leaf nodes of the MHT to challenge $IPFS_N$ (Step 1). Then, $IPFS_N$ computes the corresponding leaf node by a pseudo-random permutation $Perm(k, j)$, which takes as input a key k and a integer j and outputs another integer between 1 and n. The set of nodes on the path from root to the leaf node is denoted by $\rho(Perm(k, j))$. To compute the membership proof π, let $\rho = \{\rho(Perm(k, 1)), \ldots, \rho(Perm(k, b))\}$. $IPFS_N$

Step 1:		
1	$Blockchain_N$:	Choose $b \in [1, n]$, $k \in \{0, 1\}^\lambda$
2	$Blockchain_N \rightarrow IPFS_N$:	Send $IPFS_N$ with (b, k)
Step 2:		
3	$IPFS_N$:	For each j $(1 \leq j \leq b)$, compute the set of nodes $\rho(Perm(k, j))$.
	$IPFS_N$:	Generate proof π from $\{\rho(Perm(k, 1)), \ldots, \rho(Perm(k, b))\}$
4	$User_N \rightarrow Blockchain_N$:	Send proof π and certificate operations corresponding to the challenge
Step 3:		
5	$Blockchain_N$:	Verify the signature of each operation.
	$Blockchain_N$:	Compare $root'$ and $root$, where $root'$ is calculated based on π and operations.
6	$Blockchain_N$:	Broadcast $root$ to the blockchain network.
	$Blockchain_N \rightarrow IPFS_N$:	Reject the storage request.

Fig. 6. Lightweight correctness validation.

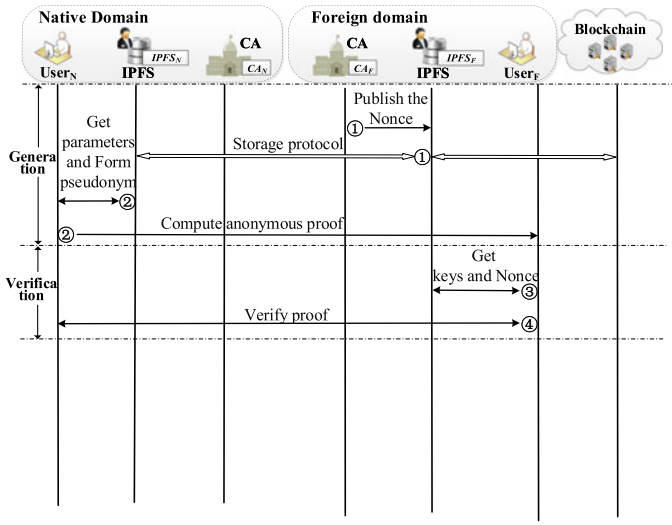


Fig. 7. Cross-domain anonymous authentication protocol.

determines the set of sibling nodes of each node in ρ, which is denoted by σ, and computes $\pi = \sigma \setminus \rho$, the set difference of ρ from σ (Step 2). At last, $Blockchain_N$ validate whether the root is correct through π and b operations. If the result is true, it indicates that $root$ is credible. Otherwise, the $root$ is discarded (Step 3).

5 Cross-domain Authentication

To protect the privacy of cross-domain users, we propose an anonymous authentication protocol based on the ZKP and pseudonym techniques (Section 5.1). We also design a compact validation function for the ZKP keys (Section 5.2).

5.1 Anonymous Authentication

In the anonymous authentication, we assume that $User_N$ and $User_F$ are two users in different security domains. At this time, $User_N$ initiates a cross-domain access request, and $User_F$ needs to verify the identity of $User_N$. The detailed protocol is shown in Fig. 7.

5.1.1 Anonymous proof generation (see Fig. 8)

To prevent the replay of anonymous proofs, CA_F periodically publishes a nonce to $IPFS_F$ (Step 1). When $User_N$ intends to access $User_F$ in the foreign domain, it obtains ZK keys and auxiliary data (used to verify the certificate) from

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

Step 1:		
1	CA_F:	Choose the current latest block hash as a nonce r
	$CA_F \rightarrow IPFS_F$:	Publish the nonce
2	$IPFS_F \leftrightarrow Blochchain$:	Store in blockchain
3	$IPFS_F \rightarrow$ All IPFS nodes:	Synchronize
Step 2:		
4	$User_N \leftrightarrow IPFS_N$:	Request nonce r, the public evaluation key EK_F, and auxiliary aux
	$User_N$:	Generate $Nym_N = g_0^{sk} g_1^r$
	$User_N$:	Compute $\{y, \pi_y\} = Compute(EK_F, u, w)$ where $u = \{Nym_N, r\}$ and $w = \{Cert_N, aux, sk\}$.
5	$User_N \rightarrow User_F$:	Send $\{y, \pi_y\}$

Fig. 8. Anonymous proof generation.

Step 1:		
1	$User_F \rightarrow IPFS_F$:	Request the public verification key VK_F and r
	$IPFS_F \rightarrow User_F$:	Return the verified VK_F and r
Step 2:		
2	$User_F$:	Get Nym_N and the proof provided by $User_N$
	$User_F \leftrightarrow User_N$:	Execute $Verify(VK_F, u, y, \pi_y)$.

Fig. 9. Anonymous proof verification.

$IPFS_N$ and generates a pseudonym Nym_N based on the nonce published by CA_F (Step 2). Then, $User_N$ can computes an anonymous proof $\{y, \pi_y\}$ and provides it to $User_F$.

5.1.2 Anonymous proof verification (see Fig. 9)

Anonymous verification is performed by $User_F$. First, $User_F$ obtains the ZK keys from $IPFS_F$ (Step 1). Then it takes pseudonym Nym_N, nonce r, and public verification key VK_F as parameters to verify the anonymous proof $\{y, \pi_y\}$ (Step 2). If the verification is valid, $User_F$ completes cross-domain anonymous authentication and establishes a connection with $User_N$. Otherwise, authentication fails and access is denied.

5.2 Validation Function

ZKP-based cross-domain anonymous authentication needs to define a concise and effective relation function F in advance.

In general, the proof $\{y, \pi_y\}$ is valid if and only if the certificate is valid and the pseudonym is legal. Therefore, we define the function F as certificate verification $CertV$ and pseudonym verification $NymV$. Since F is represented as an arithmetic circuit and determines the performance of the key and the proof generation, we need to reduce the logic complexity of F as much as possible and combine the different logic in the form of a circuit. The implementation of F is shown in Algorithm 1.

In the algorithm, the certificate verification $CertV$ consists of four steps. The first step is the verification of the certificate subject $SubjectV$, where the subject can be the domain name, user name, or other information that uniquely identifies the user. The second step is signature verification $SigV$, which uses the CA public key to verify the signature of the certificate. The third step is the CRL verification. In addition to comparing the validity of the certificate with the current time, XAuth also needs to check whether the certificate has been revoked through the serial number. The last step is the certificate transparency verification. XAuth extracts the SCTs from the certificate extensions and checks its signature. Furthermore, validation will fail if there is not a sufficient number of SCTs. As for the pseudonyms verification $NymV$, we calculate the Nym_N again through parameter r and compare the consistency.

Algorithm 1. Validation

Input: $Cert_N$, CRL_N, $pk_{CA}^{N,\ldots,F}$, $subject$, Nym_N, r, sk.
Output: $b \in \{1, 0\}$. (The certificate and pseudonym is valid or not.)

```
procedure ValidationCert_N, CRL_N, pk_CA^{N,...,F}, subject, Nym_N, r, sk
  if CertV(Cert_N, CRL_N, pk_CA^{N,...,F}, subject) → 1 then
    if NymV(Nym_N, r, sk) → 1 then
      return 1;
    else  return 0;
  else  return 0;
procedure CertVCert_N, CRL_N, pk_CA^{N,...,F}, subject
  T_NotAfter ← Extract{Cert^N};
  T_Current ← Extract{Time};
  Subject_N ← Extract{Cert^N};
  N_serialN ← Extract{Cert^N}
  SCT_N^{n+1,...,f} ← Extract{Cert^N};
  if SubjectV(Subject_N, subject) → 0 then return 0;
  if SigV(Cert^N, pk_CA^N) → 0 then return 0;
  if T_Current > T_NotAfter then return 0;
  if N_serialN ∈ CRL_N then return 0;
  if f − n + 1 < minSCT then return 0;
  if SigV(SCT_N^{n+1,...,f}, pk_CA^{N+1,...,F}) → 0 then return 0;
  return1;
procedure NymVNym_N, r, sk
  if g_0^sk g_1^r==Nym_N then return 1;
  else return 0;
```

6 Security Analysis

We formally define soundness, anonymity, and correctness properties and prove that the cross-domain anonymous authentication in XAuth satisfies these properties. Then, we analyze XAuth's security against various attacks.

Definition 1 Soundness. *The scheme is stable and unforgeable for all functions* $\mathbf{F}$ *and probabilistic polynomial-time adversaries* $\mathbf{A}$, *we have*

$$Pr\left[\begin{array}{c}(EK_F, VK_F) \leftarrow \mathbf{KeyGen}(F, 1^\lambda) \\ (\hat{Nym}, \hat{r}, \hat{y}, \hat{\pi}_y) \leftarrow \mathbf{A}^{Simulate, Forgery}(EK_F): \\ \mathbf{F}(\hat{Nym}, \hat{r}) \neq \hat{y} \\ \mathbf{Verify}(VK_F, \hat{Nym}, \hat{r}, \hat{y}, \hat{\pi}_y) = 1\end{array}\right] \approx 0$$

where

- *Simulate returns simulated pseudonym* $\hat{Nym} = g_0^{r_0} g_1^{\hat{r}}$ *as a statement of the privacy input Cert runned by adversaries. Even if Cert does not disclose to adversaries. Where* r_0 *and* $\hat{r}$ *are fillers.*
- *Forgery takes simulated pseudonyms as input and calls the* $Compute(EK_F, \hat{Nym}, \hat{r})$ *to forge the proof* $(\hat{y}, \hat{\pi}_y)$. *Or, adversaries directly intercept users' pseudonym Nym and runs the Forgery. Since the pseudonym is a public input, the effect is consistent with the former.*

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

Definition 2 Anonymity. *The scheme is zero-knowledge for all adversaries* $\mathbf{A}$*, we have*

$$Pr\begin{bmatrix} (EK_F, VK_F) \leftarrow \mathbf{KeyGen}(F, 1^\lambda) \\ (Cert, Nym, r) \leftarrow \mathbf{A}(EK_F) \\ (y, \pi_y) \leftarrow \mathbf{Compute}(EK_F, Nym, r, Cert) : \\ \mathbf{F}(Nym, r, Cert) = y \\ \mathbf{Verify}(VK_F, Nym, r, y, \pi_y) = 1 \end{bmatrix}$$

$$\approx Pr\begin{bmatrix} (EK_F, VK_F, \tau) \leftarrow \mathbf{S}_1(F, 1^\lambda) \\ (Cert, Nym, r) \leftarrow \mathbf{A}(EK_F) \\ (y, \pi_y) \leftarrow \mathbf{S}_2(EK_F, Nym, r, \tau) : \\ \mathbf{F}(Nym, r, Cert) = y \\ \mathbf{Verify}(VK_F, Nym, r, y, \pi_y) = 1 \end{bmatrix}$$

where

- $A(EK_F)$ *provides the pseudonym* Nym *and part of private input Cert of the prover. However, the possibility of adversaries obtaining both* $Cert$ *and* sk *is negligible.*
- (S_1, S_2) *is a simulator.* S_1 *output trapdoor* τ*.* S_2 *takes* τ *as input and output a simulated proof* π_y*.*

Definition 3 Correctness. *The scheme is correct for all adversaries* $\mathbf{A}$*, we have*

$$Pr\begin{bmatrix} (EK_F, VK_F) \leftarrow \mathbf{KeyGen}(F, 1^\lambda) \\ (Cert, Nym, r) \leftarrow \mathbf{A}(EK_F) \\ (y, \pi_y) \leftarrow \mathbf{Compute}(EK_F, Nym, r, Cert) : \\ \mathbf{F}(Nym, r, Cert) = y \\ \mathbf{Verify}(VK_F, Nym, r, y, \pi_y) = 1 \end{bmatrix} = 1$$

where $Cert$ *is valid and issued to the adversary. The adversary also has* sk *corresponding to* $Cert$*.*

Theorem 1. *In XAuth, the cross-domain anonymous authentication is stable, anonymous, and correct, if the ZKP algorithm is implemented correctly and the pseudonym generation is pseudo-random.*

Proof. Since XAuth implements cross-domain anonymous authentication based on the ZKP algorithm, its soundless, anonymity and correctness relies on the latter.

`Soundless` depends on that adversaries can not learn all private inputs Nym and sk. For each pair $(Nym, r, Cert, sk)$, we can get the proof (y, π_y) by calling the $Compute(EK_F, Nym, r, Cert, aux, sk)$, where $y = F(Nym, r, Cert, aux, sk)$ and π_y is the proof of the correctness of y. According to the definition of the ZKP algorithm, for any ϵ, the equation holds if and only if $\epsilon = sk$. In other words, we have $Verify(VK_F, Nym, r, y, \pi_y) = 1$ when sk corresponds to $Cert$. It is impossible for adversaries to obtain $Cert$ and sk at the same time. Thus, the possibility of adversaries forging (y, π_y) and deceiving verifiers is negligible.

`Anonymity` follows from the zero knowledge property of the ZKP algorithm and the pseudo-randomness of pseudonym. During the cross-domain anonymous authentication, verifiers only disclose the random r and the pseudonym Nym. With the change of r, adversaries cannot associate Nym with verifiers' identities. For provers, although $Cert$ and sk are takes as private inputs to compute the proof (y, π_y), the process is performed locally by the prover. Only (y, π_y) is disclosed to verifiers. According to (y, π_y), F and Nym, it is difficult for adversaries to calculate any of the private inputs $Cert$ and sk. The identities of provers are also not disclosed. Therefore, the entire cross-domain authentication is anonymous.

`Correctness` relies on the correct execution of cross-domain authentication. For the validation function $\mathbf{F}$, and any input $Cert$ and Nym, we can obtain the proof $(y, \pi_y) = Compute(EK_F, Nym, r, Cert, aux, sk)$. If sk is the secret key of $Cert$ and $Cert$ is also valid, we always get $Verify(VK_F, Nym, r, y, \pi_y) = 1$. Otherwise, the verification fails $Verify(VK_F, Nym, r, y, \pi_y) = 0$. Hence, the cross-domain anonymous authentication fits the definition of correctness. □

Next, we analyze XAuth's security against various attacks.

Split-World Attack: The core of the split-world attack is to let the malicious log server in CT provide inconsistent log data to users and auditors. The malicious log server maintains two versions of logs: *correct version* and *malicious version*. The former is shown to the auditor for the transparent audit. The latter (including the malicious certificates) is displayed to the victim user. The victim user cannot distinguish whether the log currently received is the correct version. In XAuth, logs are stored in IPFS and verified by the blockchain. IPFS and blockchain together constitute a unique log server. Both auditors and users can get the correct logs through the unique log server. Therefore, XAuth can fundamentally avoid the split-world attack.

Impersonation Attack: An adversary can use a fraudulent certificate similar to legitimate user identities to trick the victim into believing that he/she is a legitimate user. However, in XAuth, the CA needs to sign the pre-certificate and record it in blockchain and IPFS for public audit by foreign CAs. In other words, if an adversary initiates an impersonation attack, the corresponding pre-certificate will be recorded and audited by foreign CAs. When these CAs detect illegal or harmful pre-certificates, they will not issue SCTs to the pre-certificates. Due to the lack of a valid SCT, the certificate eventually is considered invalid in cross-domain authentication. Therefore, the impersonation attack will not affect the security of XAuth.

Bypass attack: The Bypass attack is mainly an attack against our storage protocol. This attack is similar to the impersonation attack, except that the pre-certificate of the fraudulent certificate owned by the adversary is not recorded in XAuth. Thereby, adversary can avoid CT's audit and trick the victim into believing that his/her identity is legitimate. However, this problem can also be solved in cross-domain authentication. In Section 5.2, certificates validation processes include verification of whether a sufficient number of legitimate SCTs are embedded in the certificate. In other words, even if the pre-certificate of fraudulent certificate without recording in our system, the certificate is also identified invalid.

7 Experiment and Evaluation

7.1 Implementation

We implement a prototype system for XAuth. Specifically, we use OpenSSL (v1.1.1) and Node.js (v8.17.0) to implement

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

TABLE 1
The Relationship Between the Number of Leaf Nodes and the Size of MMHT

Number	Leaf node size	MMHT size	Root size
4	125byte	503byte	64byte
8	125byte	1007byte	64byte
16	125byte	1.97kb	64byte
32	125byte	3.95kb	64byte
64	125byte	7.92kb	64byte
128	125byte	15.8kb	64byte

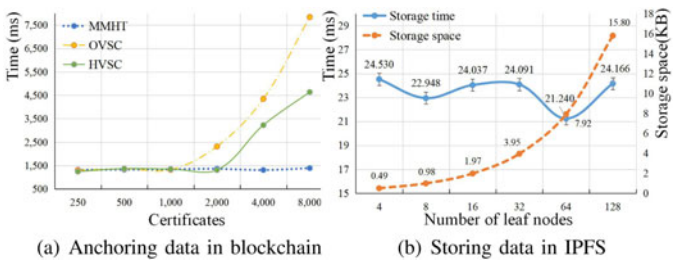


Fig. 10. Time cost in data storage.

CAs. Blockchain is based on Ethereum (v1.8.4) and communicates with other entities through the API `Web3`. IPFS uses version 0.5.0-dev. The prototype system is written in Node.js, and the hash algorithm adopts SHA-256. In addition, the zero-knowledge proof algorithm utilizes Pinnochio (PGHR13) [18]. The prototype system is composed of 5 security domains, and each security domain contains at least one CA. The prototype system is implemented with Intel Core i7-6500U CPU @2.5 GHz, 8 G RAM, and Ubuntu 16.04 operation system.

7.2 Result Analysis

We evaluate the performance of the prototype from three modules, cross-domain data storage, cross-domain data control, and anonymous authentication. In XAuth, we store the certificate operations in leaf nodes of MMHT. The size of a single certificate operation is 125 bytes. To measure the performance of XAuth more accurately, we conduct tests on MMHT with different numbers of leaf nodes, and all measurements are given as the average over 50 test runs. Before the assessment, we analyze the relationship between the number of leaf nodes and the size of MMHT in Table 1. The size of MMHT increases exponentially with the number of leaf nodes.

Performance on the Storage Protocol. We measure the time spent in each step of the cross-domain data storage protocol, including data storage, data inquiry, and data recovery. In the data storage, we separately analyze the time spent in the storage layer and the control layer. As presented in Fig. 10a, the time of MMHT required for anchoring data in blockchain is constant, about 1.3s. Particularly, we compare the storage consumption under other structures, including storing the original value of a single certificate (OVSC) and storing the hash value of a single certificate (HVSC). Obviously, compared to these structures, MMHT can handle more certificates and respond faster. As shown in Fig. 10b, the time spent in IPFS is approximately 23ms. However, the space consumption in IPFS is getting larger with the number of leaf nodes increases. From the perspective of the complete storage process, the performance of the data storage is mainly affected by the blockchain network. However, the total time required for complete storage is less than 2s. Thus, the practical effect of cross-domain storage is acceptable.

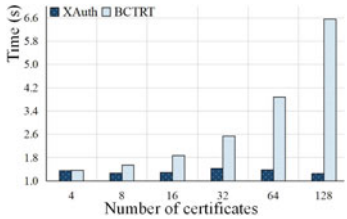


Fig. 11. Time cost in data inquiry.

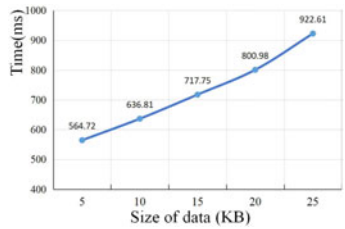


Fig. 12. Time cost in data recovery.

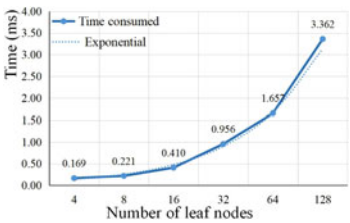


Fig. 13. Time cost in fast data collection and binding.

Then, we give a comparison about the time cost between XAuth and BCTRT [10] in data inquiry. In general, data inquiry includes requesting and verifying data. The results are shown in Fig. 11. The inquiry time of BCTRT increases exponentially with the number of certificates. On the contrary, our scheme is not affected by the number of certificates, which is approximately 1.32s, since we separate the storage and control layers and implement batch verification. Thus, when there are a large number of user requests, XAuth can respond more quickly.

For data recovery, we test the data of different magnitudes and the results are presented in Fig. 12. The time required for data recovery increases linearly with the size of the data. Therefore, the IPFS nodes need approximately 0.7s to recover the MMHT containing 128 leaf nodes, which can meet the demands of users.

Performance on the Control Protocol. We investigate the detailed processing time of cross-domain data control protocol. As shown in Fig. 13, IPFS nodes only need 3.2ms to bind 128 certificate operations. In other words, it only takes 25 μs to collect a certificate operation on average. Besides, we also compare the transaction verification latency among BCTRT and XAuth in Fig. 14. We find that the average time for BCTRT to verify the correctness of a single certificate in a transaction is 13.52ms. Similarly, the time for XAuth is only 5ms and shortens as the number of certificates

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

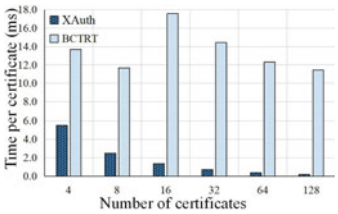


Fig. 14. Time cost in lightweight correctness validation.

TABLE 2
Cross-Domain Anonymous Authentication Protocol

Function	Equations	Generate Proof	Proof	Verify
V_Signature	142,945	22.3s	288bytes	9ms
V_Validity	244,626	39.7s	288bytes	9ms
V_SCT	232,715	29.4s	288bytes	9ms
V_Nym	17,405	2.7s	288bytes	9ms
Total	614,286	89.7s	288bytes	9ms

increases. Compared with BCTRT, XAuth can pack more certificates into the transaction and verify its correctness in a shorter time, because we design a lightweight correctness validation protocol in the control layer to reduce the impact of MMHT on transaction verification time.

Performance on the Authentication Protocol. We measure the performance of cross-domain anonymous authentication protocol. In practice, we mostly care about the verification time of the anonymous proof, which directly affects the users' experience. As shown in Table 2, the $User_N$ only needs to transmit 288Byte proof to prove his/her identity, while the $User_F$ can verify the proof in about 9 ms. Therefore, compared to BCTRT, Certchain and CertLedger, our scheme not only meets the requirements of user privacy protection but also ensure fast cross-domain authentication.

8 Related Work

As shown in Fig. 15, existing cross-domain authentication schemes can be divided into two categories according to whether they are based on blockchain technology: *centralized* and *distributed*.

8.1 Centralized Solutions

In centralized solutions, two security domains can establish a trust relationship through a third-party authority. According to the actual topology structure of CA, the centralized solutions can be divided into four methods.

The first method is the bridge pattern. In BCA [19], Polk and Hastings proposed the Bridge Certification Authority (BCA) that a third-party CA is used as a bridge to connect multiple CA's. Liu and Yang [20] also proposed a bridge pattern that constructing a trusted proxy for certificate validation. Oauth2.0 [21], a single sign-on protocol widely used in E-commerce, is also a bridge connection mode, which provides a compact standard to ensure the secure authorization of user resources in the network. However, in the bridge pattern, there must be a third-party trust center node. An attack on the center node can easily break the trust chain. Therefore, these schemes all have the problem of single point of failure.

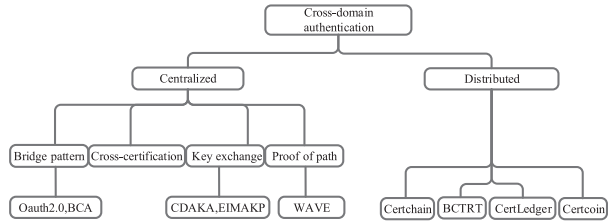


Fig. 15. Related work.

The second method is cross-certification, which is suitable for PKI with a net structure. Bai *et al.* [22] proposed that peer CAs can communicate with each other by issuing certificates to each other. Certificate pairs describe their two-way trust relationship. However, due to the equivalence relationship between CAs, the extension and discovery of certificate paths are difficult and will consume a lot of computing power and even lead to the situation of a dead loop.

The third method is the key exchange. In EIMAKP [23], Yuan *et al.* proposed key negotiation between two heterogeneous domains to achieve cross-domain authentication between CAs in the same level of the security domain. However, in this scheme, users need to carry a large amount of computation and communication, and the verification efficiency was low. Liu and Ma [24] proposed a heterogeneous cross-domain authenticated key agreement protocol to provide identity identification for users from two different domains. Nevertheless, this scheme conflicts with the existing PKI system and the authentication process is tedious.

The fourth method is proof of path, such as WAVE [25]. WAVE adopts an expressive authorization model and provides a cross-domain authentication method for IoT devices in different security domains through path certification. However, the storage layer of this scheme does not guarantee confidentiality and integrity. In addition, since path selection is required during verification, it is vulnerable to attacks such as path forgery, which makes the data verification process tedious and inefficient.

8.2 Distributed Solutions

Distributed authentication solutions are to establish trust between different security domains through distributed ledgers and consensus. To achieve mutual recognition of identities, these solutions often directly record the certificate and its status in distributed ledgers to facilitate audit and authentication [7], [8], [9], [10], [26], [27]. For instance, Lewison and Corella [26] proposed a blockchain PKI without requiring CRLs or OCSP, which solves the long-standing problems of traditional PKI. Malik *et al.* [28] proposed a blockchain-based vehicle network authentication and revocation framework, which reduces the computation and communication overhead by relying on CA as little as possible. However, these schemes simply associate the blockchain as a database with the traditional PKI systems and do not consider the issues such as low throughput, user privacy leakage, and high latency.

With extensive research on blockchain-based PKI, more practical solutions are proposed. Certcoin [7] and Blockstack [27] are decentralized PKI authentication systems improved on top of Namecoin [29]. These two solutions are dedicated to adopting a more secure and decentralized way to solve the trust problem in traditional PKI systems. In addition, Certchain

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

[8], CertLedger [9], and BCTRT [10] introduce a blockchain-based certificate auditing model. Through decentralization and auditing mechanisms, a distributed solution of multi-CA collaboration was implemented, which can solve problems such as single-point failure and cross-domain authentication. Moreover, Certchain additionally designs a consensus protocol based on dependability-rank to achieve decentralized trust. BCTRT adopt certificate transparency and revocation transparency mechanisms to strengthen the security guarantees of blockchain-based certificates. Nevertheless, none of the above solutions consider the problem of low throughput of blockchain. In the face of mass identity data in cross-domain authentication, it is not appropriate to directly storing identity, status, logs, and other data on the blockchain. Furthermore, the above solutions rarely have complete privacy protection schemes for users. Especially in the cross-domain authentication process, it is extremely important and necessary to protect the privacy of users in different security domains.

9 Conclusion

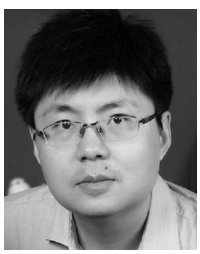
To solve the cross-domain authentication problem in the PKI system, we propose an efficient privacy-preserving cross-domain authentication scheme (XAuth) that is compatible with both existing PKI and CT systems. Specially, we adopt IPFS and blockchain to decouple storage and control layers to improve the performance and security of XAuth. To meet the demands of rapid response, we design a lightweight correctness validation protocol based on an MMHT structure. We also present a privacy-preserving cross-domain authentication method that utilizes zero-knowledge proof algorithm. The security analysis and experimental results show that XAuth is efficient and suitable in practice.

Acknowledgments

This work was supported in part by the National Natural Science Foundation of China under Grants 61772383, U1836202, 62076187 in part by the Joint fund of Ministry of Education of China for Equipment Pre-research under Grant 6141A02033341.

References

[1] J. Aas *et al.*, "Let's encrypt: An automated certificate authority to encrypt the entire web," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2019, pp. 2473–2487.
[2] T. White, "Cross-domain enterprise service (CDES)," *DISA, Defense Information Systems Agency, A Combat Support Agency*, 2009.
[3] "PKI issues - 10 things I wish they warned me about PKI," 2016. [Online]. Available: http://www.articsoftpgp.com/pki_issues.htm
[4] M. Wang, C. Qian, X. Li, and S. Shi, "Collaborative validation of public-key certificates for IoT by distributed caching," in *Proc. IEEE Conf. Comput. Commun.*, 2019, pp. 847–855.
[5] M. O'Neill *et al.*, "Trustbase: An architecture to repair and strengthen certificate-based authentication," in *Proc. USENIX Secur. Symp.*, 2017.
[6] J. Chen, S. Yao, Q. Yuan, R. Du, and G. Xue, "Checks and balances: A tripartite public key infrastructure for secure web-based connections," in *Proc. IEEE Conf. Comput. Commun.*, 2017, pp. 1–9.
[7] C. Fromknecht, D. Velicanu, and S. Yakoubov, "Certcoin: A namecoin based decentralized authentication system," Massachusetts Inst. Technol., Cambridge, MA, USA, 2014.
[8] J. Chen, S. Yao, Q. Yuan, K. He, S. Ji, and R. Du, "Certchain: Public and efficient certificate audit based on blockchain for TLS connections," in *Proc. IEEE Conf. Comput. Commun.*, 2018, pp. 2060–2068.
[9] M. Y. Kubilay, M. S. Kiraz, and H. A. Mantar, "Certledger: A new PKI model with certificate transparency based on blockchain," *Comput. Secur.*, vol. 85, pp. 333–352, 2019.
[10] Z. Wang, J. Lin, Q. Cai, Q. Wang, D. Zha, and J. Jing, "Blockchain-based certificate transparency and revocation transparency," *IEEE Trans. Dependable Secure Comput.*, to be published, doi: 10.1109/TDSC.2020.2983022.
[11] "Certificate transparency in OpenSSL," 2018. [Online]. Available: https://www.openssl.org/docs/man1.1.0/crypto/ct.html
[12] "Certificate transparency in Chrome," 2018. [Online]. Available: https://groups.google.com/a/chromium.org/forum/#!msg/ct-policy/wHILiYf31DE/iMFmpMEkAQAJ
[13] "Certificate transparency in Nginx," 2018. [Online]. Available: http://www.certificatetransparency.org/resources-for-site-owners/nginx
[14] "Certificate transparency in Microsoft," 2018. [Online]. Available: https://blogs.msdn.microsoft.com/azuresecurity/2018/04/25/certificate-transparency/
[15] B. Li, J. Lin, F. Li, Q. Wang, Q. Li, J. Jing, and C. Wang, "Certificate transparency in the wild: Exploring the reliability of monitors," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2019, pp. 2505–2520.
[16] J. Benet, "IPFS-content addressed, versioned, P2P file system," 2014, *arXiv:1407.3561*.
[17] B. Laurie, "Certificate transparency," RFC 6962, 2014.
[18] B. Parno, J. Howell, C. Gentry, and M. Raykova, "Pinocchio: Nearly practical verifiable computation," in *Proc. IEEE Symp. Secur. Privacy*, 2013, pp. 238–252,.
[19] W. T. Polk and N. E. Hastings, "Bridge certification authorities: Connecting B2B public key infrastructures," in *Proc. PKI Forum Meeting*, 2000.
[20] Y. Liu and Z. Yang, "The research and design of the proxy for certificate validation based on distributed cross-certification," in *Proc. 5th Int Conf. Appl. Comput. Inf. Technol./4th Int. Conf. Comput. Sci./Intell. Appli. Inform./2nd Int. Conf. Big Data Cloud Comput. Data Sci.*, 2017, pp. 135–140.
[21] D. Hardt *et al.*, "The OAuth 2.0 authorization framework," RFC 6749, 2012.
[22] Q. H. Bai, Y. Zheng, L. N. Zhao, H. Chun, and C. Y. Cheng, "Research on mechanism of PKI trust model," *Appl. Mechanics Materials*, vol. 536–537, pp. 694–697, 2014.
[23] C. Yuan, W. Zhang, and X. Wang, "EIMAKP: Heterogeneous cross-domain authenticated key agreement protocols in the EIM system," *Arabian J. Sci. Eng.*, vol. 42, pp. 3275–3287, 2017.
[24] X. Liu and W. Ma, "CDAKA: A provably-secure heterogeneous cross-domain authenticated key agreement protocol with symptoms-matching in TMIS," *J. Med. Syst.*, vol. 42, 2018, Art. 135.
[25] M. P. Andersen *et al.*, "WAVE: A decentralized authorization framework with transitive delegation," in *Proc. USENIX Secur. Symp.*, 2019.
[26] K. Lewison and F. Corella, "Backing rich credentials with a blockchain PKI," 2016.
[27] M. Ali, J. C. Nelson, R. Shea, and M. J. Freedman, "Blockstack: A global naming and storage system secured by blockchains," in *Proc. USENIX Conf. Usenix Annu. Techn. Conf.*, 2016, pp. 181–194.
[28] N. Malik, P. Nanda, A. Arora, X. He, and D. Puthal, "Blockchain based secured identity authentication and expeditious revocation framework for vehicular networks," in *Proc. TrustCom/BigDataSE*, 2018, pp. 674–679
[29] H. A. Kalodner, M. Carlsten, P. Ellenbogen, J. Bonneau, and A. Narayanan, "An empirical study of namecoin and lessons for decentralized namespace design," in *Proc. Workshop Economics Inf. Secur.*, 2015.



Jing Chen received the PhD degree in computer science from the Huazhong University of Science and Technology, Wuhan. He is currently a professor with the Key Laboratory of Aerospace Information Security and Trusted Computing, Ministry of Education, School of Cyber Science and Engineering, Wuhan University, Wuhan. He has published more than 140 research papers in many international journals and conferences, such as the *IEEE Transactions on Information Forensics and Security*, *IEEE Transactions on Dependable and Secure Computing*, *IEEE Transactions on Mobile Computing*, *USENIX Security and INFOCOM*. His research interests include the areas of network security and cloud security.

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.

Zeyi Zhan received the bachelor's degree in computer science and technology from Wuhan University, China, in 2018. He is currently working toward the master's degree in network science at Wuhan University, Wuhan, China. His research interests include identity authentication, blockchain and privacy protection.

Kun He received the PhD degree in computer science from Wuhan University, Wuhan. He has published research papers in the *IEEE Transactions on Information Forensics and Security*, *IEEE Transactions on Dependable and Secure Computing*, *IEEE Transactions on Mobile Computing*, *USENIX Security and INFOCOM*. His research interests include cryptography, network security, mobile computing, and cloud computing.

Ruiying Du received the BS, MS, and PhD degrees in computer science from Wuhan University, Wuhan, China, in 1987, 1994, and 2008, respectively. She is currently a professor with the School of Cyber Science and Engineering, Wuhan University. She has published more than 80 research papers in many international journals and conferences, such as the *IEEE Transactions on Information Forensics and Security*, USENIX Security, INFOCOM, SECON, and TrustCom. Her research interests include network security, wireless network, and mobile computing.

Donghui Wang received the master's degree in computer science from Jilin University. She is currently a senior engineer with Huawei Technologies Co., Ltd. She has more than ten years experience in research, security, analysis, and system design under various security projects. Her current research interests include blockchain, telecom network security, privacy protection, etc.

Fei Liu received the master's degree in computer science from Shandong Industry University. She is currently a distinguished engineer with Huawei International PTE LTD. She has more than 17 years experience of research and design in telecommunication, mobile services, terminals and cyber security through 2G to 5G. She is working on 6G end-to-end security policy and technologies, including trust model, security framework and architecture, AAA and AI for security etc.

▷ **For more information on this or any other computing topic, please visit our Digital Library at** www.computer.org/csdl.

Authorized licensed use limited to: Wuhan University. Downloaded on August 01,2023 at 11:58:53 UTC from IEEE Xplore. Restrictions apply.